Blast.fun Security Assessment

Prepared by: GiveRep

Eason Chen

Report issued: November 6, 2026

Assessment period: November 3 to 5, 2026

Reviewed revisions:

`850d8227...`, `8c04789d...`, `b50d0c3b...`

Status: Draft for client review

Contents

1 Executive summary **2**

2 Project overview **2**

3 Assessment scope and revisions **2**

3.1 Packages reviewed 2

3.2 Revision table 3

3.3 Out of scope 3

4 Methodology **3**

5 Results summary **3**

6 Findings **4**

6.1 Confirmed vulnerabilities 4

6.2 Low findings 4

6.2.1 LOW-01: the coin `TreasuryCap` is released to the publisher before venue preparation and may allow Cetus pool pre-creation 4

6.2.2 LOW-02: permissionless auto-LP compounding has no price bound 5

6.2.3 LOW-03: LP custody is no-exposed-withdrawal, not permanent, through an upgradeable migrators package 5

6.2.4 LOW-04: permissionless settle and cancel of an ignored funded presale . . . 6

6.2.5 LOW-05: a proposal can collapse future notice to zero 6

6.3 Informational observations 6

6.4 Reported items pending resolution 8

6.4.1 REP-01: repeated `vault::share_with_position` calls (third-party report, not a GiveRep finding) 8

6.5 Refuted candidates 8

6.6 Unverified hypotheses 9

7 Test scope **9**

8 Trusted dependencies and administrative assumptions **10**

9 Revision and remediation history **10**

10 Limitations **10**

11 Appendix: source references **11**

1 Executive summary

No confirmed security vulnerabilities were identified in the reviewed scope.

GiveRep reviewed the Blast.fun launchpad, presale, migrators, admin, vault, and core packages, including the refactor and its follow-up changes. The assessment covered access control, upgrades, asset custody, pricing, fees, migration, and holder rewards. The liquid-staking source was also compared with issues reported in audits of other Sui liquid-staking protocols.

The report records five Low findings and fifteen informational observations, with no Critical, High, or Medium finding established. GiveRep identified the release of the generated coin's `TreasuryCap` before venue preparation, and the project addressed it by sealing the capability. The remaining Low items concern auto-LP compounding, upgrade authority, presale cancellation, and administrative notice periods. A maintainer-reported concern about repeated vault sharing remains open.

The liquid-staking package (`blast_sui`) does not compile at the frozen revision and is out of scope for a security assurance; its current deployment and any live value remain unknown.

2 Project overview

Blast.fun is a Sui launch protocol in two parts. A launchpad (`blast_fun`) lets creators launch a new coin (the Meme) on a constant-product bonding curve priced in an admitted Quote coin. A presale (`blast_presale`) runs an escrowed presale with fee and creation policies. Both products hand their liquidity to an admitted migration adapter (`blast_migrators`), which seeds a DEX pool on Cetus or Bluefin. A shared vault (`blast_vault`) holds LP custody, holder rewards, and auto-LP and buyback accounting. Shared administration (`blast_admin`) and shared arithmetic and treasury primitives (`blast_core`) sit underneath.

The refactor under review consolidated these packages and their dependency closure into one stack, and introduced a sealed treasury-cap design (ADR 0138) that changes how the generated coin's mint authority is held between publication and venue preparation.

3 Assessment scope and revisions

3.1 Packages reviewed

Package	Contents reviewed
`blast_admin`	ACL, delayed-action primitives, `PackageAdmin` / `PackageVersion`
`blast_core`	Basis-point arithmetic, apportionment, payout and vesting, fee split, protocol-fee ledger, treasury, Merkle, migration hand-off, owner proof, sealed treasury cap
`blast_vault`	LP custody, fee split, Blast share, partner hold, holder rewards, auto-LP and buyback, owner claims
`blast_migrators`	Cetus and Bluefin venue adapters
`blast_fun` (launchpad)	Bonding-curve launchpad, launch ticket, allocation and fees
`blast_presale`	Escrow presale, fee policy, creation policy, migration hand-off

The dependency closure was also read where it touches the six packages: `blast_partners`, `blast_fun_vesting`, `blast_fun_otc`, `launch_ticket_template`, `presale_coin_template`,

`coin_template`, and the vendored Aftermath DAO presale adapter.

3.2 Revision table

Revision	Role in this assessment	Source reviewed
`850d8227edce340a6d5d839d30efbd14b707dfc6`	Previous version (before the refactor), comparison baseline	Yes
`8c04789d3f9a8606944717841071a5fe8e4e10d1`	Refactor under primary review	Yes
`b50d0c3bee50b637a673d1ccb64b5413af4ba518`	Incremental follow-up (rename-and-clarify plus ADR 0138 sealed cap)	Yes
`ea43dbaa`	Live-main pointer at the time of writing	Not source reviewed (documentation-only, no Sui source change)

Commit `ea43dbaa` changes documentation only; the assessed Sui source remains at `b50d0c3b`.

3.3 Out of scope

The `blast_sui` liquid-staking package (13 modules, about 2,700 source lines) was inventoried, statically reviewed against known liquid-staking vulnerability classes, and compared with public audit reports of comparable products, but it is not covered by this assessment for a security assurance. It does not compile at the frozen revision (`b50d0c3b`), and its current deployment and any live value are unknown. Off-chain services, key custody, front-end components, and infrastructure are also out of scope.

4 Methodology

The assessment combined source review of the six packages and their dependency closure with disassembly of pinned mainnet Cetus (v15) and Bluefin (v17) venue bytecode, offline simulation against the project's pinned toolchain (Sui 1.77.2, Move framework `06734f6f`) using deterministic fixture keys and fictitious balances under a network-denied sandbox, and arithmetic analysis of the economic paths: the bonding curve, apportionment, rounding, supply transitions, and fee and reward accounting. Findings were checked against the repository's decision records and tests, and against public audit reports of comparable Sui liquid-staking and concentrated-liquidity products.

Severity reflects the potential impact and the authority needed to trigger the behaviour. Security findings, administrative trust assumptions, and unresolved reports are listed separately.

5 Results summary

Severity	Assessed items
Critical	0
High	0
Medium	0

Severity	Assessed items
Low	5
Informational	15

The five Low findings are: one potential-authority finding identified by GiveRep and fixed by the project in response (LOW-01), one inherited and still-open observation (LOW-02), and three trust or operational observations with explicit prerequisites that exclude an arbitrary attacker (LOW-03, LOW-04, LOW-05). One third-party report is open and unresolved (section 6.4). Refuted candidates and unverified hypotheses are listed separately and do not count as findings.

6 Findings

6.1 Confirmed vulnerabilities

None. No confirmed security vulnerability of Critical, High, or Medium severity was identified in the reviewed scope.

6.2 Low findings

6.2.1 LOW-01: the coin `TreasuryCap` is released to the publisher before venue preparation and may allow Cetus pool pre-creation

Severity

Low

Status

Resolved (identified by GiveRep; the project fixed it in response)

Affected code

`sui/launch_ticket_template/sources/meme.move` at `8c04789d` (ticket and `TreasuryCap` transferred to the publisher) and `sui/launchpad/sources/launch/launch_ticket.move` at `b50d0c3b` (fixed)

Permalinks

https://github.com/interest-protocol/blast-v2-contracts/blob/8c04789d3f9a860694471784 1071a5fe8e4e10d1/sui/launch_ticket_template/sources/meme.move#L55-L56

https://github.com/interest-protocol/blast-v2-contracts/blob/b50d0c3bee50b637a673d1ccb64b5413af4ba518/sui/launchpad/sources/launch/launch_ticket.move#L41

In the previous version the generated coin's `TreasuryCap` was sealed inside the `LaunchTicket` and only lent out through a witness-gated accessor. The refactor changed this so the ticket template transfers both the ticket and the raw `TreasuryCap` to the publisher at publication. The publisher therefore holds mint and burn authority for the interval between coin publication and venue preparation.

GiveRep investigated this as a possible economic denial of service: a malicious publisher could mint Meme, pre-create the Cetus pool for the pair the launch will later reserve, then let the launch graduate onto a pool migration cannot create again. The specific "strand buyers" chain is currently blocked, for a reason the maintainer identified and this review reproduced in a native test: `launch_ticket::destroy` asserts that the circulating supply equals the atomic supply exactly, Cetus rounds liquidity removal down so one atom stays locked in the pool, and `finalize` therefore

aborts before any buyer enters. The protection is incidental, resting on Cetus rounding rather than on custody.

Keeping the capability sealed removes the pre-preparation window without relying on Cetus rounding. The project addressed this finding: ADR 0138 introduces a `SealedTreasuryCap` that leaves the ticket only as a sealed value an admitted venue may borrow for pool preparation and only the product may open, merged at `b50d0c3b`. The seal is the fix for the custody issue; the supply check had already blocked the proposed buyer-fund lock.

Preconditions: a malicious publisher, between publication and venue preparation.

Root cause: the refactor moved mint and burn custody out of the launch ticket and into the publisher's hands for a bounded window.

Impact: potential pool pre-creation and launch disruption; the specific fund-freeze chain is blocked by the exact-supply check.

Recommendation: keep the coin's mint authority sealed until the venue has prepared the pool. Implemented.

Remediation status: resolved at `b50d0c3bee50b637a673d1ccb64b5413af4ba518`.

6.2.2 LOW-02: permissionless auto-LP compounding has no price bound

Severity
Low

Status
Open (inherited from the previous code, unchanged)

Permalink
https://github.com/interest-protocol/blast-v2-contracts/blob/b50d0c3bee50b637a673d1ccb64b5413af4ba518/sui/migrators/sources/venues/cetus.move#L247

`compound_auto_lp` on the Cetus venue adds the vault's waiting auto-LP fee balances to a full-range position at the pool's current price, with no price bound or minimum-amount assertion, so a caller can move the price, compound, and move it back within one transaction. The exposure is bounded to the auto-LP route's share of collected LP fees; the position is full-range with no removal path, and the same exposure existed in the previous code. A profitable trading sequence was not established; the potential exposure is limited to these fees.

Preconditions: none (permissionless). **Root cause:** no price bound at compounding time. **Impact:** bounded sandwiching of the auto-LP fee share. **Recommendation:** add a caller-supplied or on-chain price bound, or a TWAP oracle, and refuse outside it.

6.2.3 LOW-03: LP custody is no-exposed-withdrawal, not permanent, through an upgradeable migrators package

Severity
Low

Status
Open (trust boundary)

Permalink
https://github.com/interest-protocol/blast-v2-contracts/blob/b50d0c3bee50b637a673d1ccb64b5413af4ba518/sui/vault/sources/vault.move#L215

`vault::position_mut` and `vault::auto_lp_position_mut` lend a mutable `Position` to venue code, and the `blast_migrators` package is upgradeable with no `make_immutable` wrapper. A

compatible migrators upgrade (48-hour delay under `UpgradeAdmin`) could withdraw Bluefin migration principal or Cetus auto-LP principal. This is a trust boundary, not an arbitrary-attacker path: it requires the migrators upgrade-admin role and a 48-hour wait. The repository's own dependency notes describe the principal as held by an upgradeable package with no exposed withdrawal path, while some vault doc-comments say "permanent custody"; the doc-comments overstate it.

Preconditions: hold the migrators `UpgradeAdmin` role and wait the 48-hour delay. **Recommendation:** reconcile the vault documentation, or wrap the migrators package with `make_immutable` once it is stable.

6.2.4 LOW-04: permissionless settle and cancel of an ignored funded presale

Severity
Low

Status
Open (documented)

Permalink
https://github.com/interest-protocol/blast-v2-contracts/blob/b50d0c3bee50b637a673d1ccb64b5413af4ba518/sui/presale/sources/blast_presale.move#L851

A funded presale that nobody settles for its whole liquidity window can be settled and cancelled by anyone in one programmable transaction at the window deadline, cancelling the sale (full refunds, creator tokens locked). This is documented in the presale constants and requires a week of total inaction by every interested party; there is no theft.

Preconditions: a full week of inaction by the creator and all participants. **Recommendation:** none required; the behaviour is documented. Confirm the operator is aware of the window.

6.2.5 LOW-05: a proposal can collapse future notice to zero

Severity
Low

Status
Open (administrative trust, by design)

Permalink
https://github.com/interest-protocol/blast-v2-contracts/blob/b50d0c3bee50b637a673d1ccb64b5413af4ba518/sui/admin/sources/delayed/delayed.move#L103

`Delayed::schedule(value, next_delay=0)` lets the owning role zero all future notice after one applied wait, because the applied delay is always the wait even when the proposed next delay is zero. This applies to the treasury destination, trade and creation fees, the LP-fee share, upgrade delay, and the holder-round delay. It is reachable only by the role that owns each setting.

Preconditions: hold the relevant admin role. **Recommendation:** if any of these slots is meant to carry a notice control, enforce a minimum delay for that slot.

6.3 Informational observations

These are documentation, test-coverage, and design observations, none of which is a vulnerability.

ID	Area	Observation
INFO-01	Test coverage	The committed `creator_authority` tests are not green as committed: they hardcode signatures over a message embedding address `0xc` while `Move.toml` pins `blast_fun = 0x0`, so five account-claim tests fail as committed and pass at `0xc`. Test-harness/config mismatch, not a contract defect.
INFO-02	API surface	The seal's borrow surface exposes full mint and burn authority to admitted venues during prepare (`sealed_treasury_cap::treasury_cap_mut` returns `&mut TreasuryCap`). The only borrower uses it to mint a one-per-type pool-creation cap. Trust/API-surface observation.
INFO-03	Economics	`join_opening_round` uses unchecked u64 addition (self-denial only, requires a Quote near `u64::MAX` atoms).
INFO-04	Design	The launchpad lacks the presale's seedable-price guard and has no cancel path from `MigrationReady` (creator self-harm under extreme config, not attacker-reachable).
INFO-05	API surface	`sealed_treasury_cap::new` is public for any witness, so a `SealedTreasuryCap` object is not by itself proof of product sealing.
INFO-06	API surface	`migration::redeem_ticket` is public; a creator can discard the ticket and consume the type's single creation-cap slot (self-griefing only).
INFO-07	Tooling	`blast_presale_testkit` still produces raw `TreasuryCap`s and cannot open a presale after the seal (tooling rot, no on-chain effect).
INFO-08	Design	Protocol-share application is not settle-first, unlike fee-split application (documented asymmetry).
INFO-09	API surface	`blast_presale::destroy_cap` lacks an `assert_current` generation check (harmless).
INFO-10	Test coverage	The flagship `venue_fork` native PTB test is red at `b50d0c3b` during sealed-treasury-cap setup (a test-integration regression introduced by ADR 0138, not a vulnerability).
INFO-11	Liquid staking	`blast_sui` does not compile at `b50d0c3b`; it still imports `blast_admin::operational_version` and `blast_admin::upgrade_custody`, which were deleted in the admin fold. A real source defect.
INFO-12	Liquid staking	`boosts/aftermath_adapter` shares the same stale-admin-module compile break as INFO-11.
INFO-13	Liquid staking	Single-validator concentration plus a "rates never decrease" assumption: a sole-validator slash would make near-full redemptions fail closed until a rescue upgrade. Documented design.
INFO-14	Liquid staking	Fee admin sets the redemption fee (capped at 100 bps) with no delay; upgrade-authority delay lived in modules deleted by the admin fold and is not verifiable from the frozen tree.
INFO-15	Liquid staking	Near-full redemption is fail-closed at or below 3 MIST, a bounded rounding artifact, not a fund-conservation defect.

The liquid-staking observations (INFO-11 through INFO-15) come from a static review of the

13 `blast_sui` modules plus an arithmetic model and a historical diagnostic build. No current native `blast_sui` test coverage was produced, because the package does not compile at the frozen revision. A compatible project-local toolchain (Sui 1.77.2 with the pinned Move framework) is available, so native coverage is achievable once the compile break is fixed; it was not produced for this assessment.

6.4 Reported items pending resolution

6.4.1 REP-01: repeated `vault::share_with_position` calls (third-party report, not a GiveRep finding)

Severity
none assigned (open, reported)

Reported by
a third party, not a GiveRep discovery

Status
unresolved

Permalink
https://github.com/interest-protocol/blast-v2-contracts/blob/b50d0c3bee50b637a673d1ccb64b5413af4ba518/sui/vault/sources/vault.move#L177

The maintainer reported that repeated `blast_vault::vault::share_with_position` calls could emit duplicate `VaultCreated` events and attach unrelated objects. Sui permits shared objects to be consumed by value and shared again when supplied as shared-object transaction inputs.

A repeated call using the same venue type would encounter the existing `PositionKey<Venue>` field. However, `share_with_position` has no admission check of its own, and a call using a different, caller-defined venue type has not been tested. The event and state-integrity concern remains open.

Recommendation: add a one-shot or finalized guard to `share_with_position` to match the admission check its sibling constructor `new()` enforces.

6.5 Refuted candidates

The following proposed failure paths did not establish a security finding.

- **REF-01: Cetus pool pre-creation strands a graduated launch's buyers.** Refuted as a working exploit. The exact-supply check plus Cetus round-down removal leave the launch unopenable, so no buyer funds are stranded. The underlying custody change is retained as LOW-01.
- **REF-02: `close_round` is unreachable, permanently locking unclaimed holder rewards.** The premise is refuted: a shared object cannot be passed as an owned/immutable argument, but it can be consumed by value as a shared-object argument. A fresh native probe confirms the consume-by-value path. End-to-end recovery assertions on the current revision are not established by this run, because the flagship `venue_fork` test that exercises the path is red at `b50d0c3b` (INFO-10). No Medium finding follows.
- **REF-03: Bluefin pool duplication blocks migration.** Refuted. Disassembly of the pinned Bluefin pool bytecode shows pool creation does not enforce one pool per type pair and tier, so the migration's own creation always succeeds.
- **REF-04: Bluefin pool uniqueness lets a buyer brick migration.** Refuted on the same

evidence as REF-03.

- **REF-05: opening-round delivery lacks a last-claim remainder sweep.** Refuted: the shrinking-denominator pro-rata drains both pots to zero; only order-dependence of at most one atom remains.

6.6 Unverified hypotheses

- **UNV-01: Cetus delisting or pre-creation makes a launchpad migration abort forever.** Not established. This depends on a privileged Cetus operator action (delisting a fee tier or pre-creating the pool at the registered spacing), not an arbitrary caller, and it was not reproduced. It remains an open residual-risk hypothesis, not a confirmed finding.

7 Test scope

The review ran the package's native unit suites against the frozen revision with the project's pinned toolchain, and exercised the adversarial paths with dedicated native probes and a reproduction test.

Suite	Result
`blast_core`	85 / 85
`blast_presale`	287 / 287
`blast_admin`	198 / 198
`blast_migrators`	40 / 40
`blast_vault`	122 / 122
`blast_fun_vesting`	53 / 53
`blast_fun` (launchpad)	443 / 448 (5 pre-existing `creator_authority` signature-fixture failures, INFO-01)

The five launchpad failures come from signature fixtures using `0xc` while the manifest uses `0x0`; the affected tests pass with the fixture address. Earlier venue suites passed at `8c04789d`. At `b50d0c3b`, the `venue_fork` suite fails during sealed-capability setup and does not reach its migration assertions.

Dedicated adversarial tests:

- The H-1 rounding reproduction ran two tests across both Cetus coin orderings and two seed sizes, all confirming the one-atom residual and the `finalize` rejection (LOW-01).
- A shared-object argument-kind probe confirmed the consume-by-value and re-share behaviour (REF-02, REP-01).
- The `venue_fork` flagship native PTB test was re-run at `b50d0c3b` and is red during sealed-treasury-cap setup (INFO-10); it is not a passing execution-level check at this revision.

`blast_sui` was reviewed statically (13 modules), modelled arithmetically, and diagnosed historically; it does not compile at the frozen revision, so no current native `blast_sui` test coverage is claimed.

The environment used offline simulation with deterministic fixture keys and fictitious balances, with network access denied. No real wallet, key, chain signing, broadcast, or mutation was used.

8 Trusted dependencies and administrative assumptions

The assessment relies on the following components and administrative controls.

- The `blast_admin` ACL issues a role's witness only to a live `AdminCap` holding that role, and delays root transfers.
- `blast_partners` pays a partner at most its share of Blast's fee (capped at 80%) and enforces removal notice periods.
- The Sui framework and the Move standard library are trusted for `Balance/Coin` conservation, the coin registry supply modes, dynamic fields, package upgrade tickets, Ed25519 verification, type identity, and checked arithmetic.
- The Cetus and Bluefin venues are trusted for their documented pool-creation and liquidity-removal behaviour, resolved from pinned mainnet bytecode and, for the Cetus path, exercised in simulation.
- Root and role authority is trusted. The `SuperAdminCap` grant and `UpgradeAdmin` scheduling are stated trust assumptions, not attacker-reachable surfaces. Custody of the root and upgrade roles is assumed to follow the project's documented multisig plan.

9 Revision and remediation history

Event	Revision
Previous version (before the refactor)	`850d8227edce340a6d5d839d30efbd14b707dfc6`
Refactor under primary review	`8c04789d3f9a8606944717841071a5fe8e4e10d1`
LOW-01 identified by GiveRep (coin `TreasuryCap` custody before venue preparation)	at `8c04789d`
LOW-01 fix: ADR 0138 sealed treasury cap	`b50d0c3bee50b637a673d1ccb64b5413af4ba518`
Incremental re-audit and higher-severity hunt	`b50d0c3b`
Live-main pointer (documentation-only, not source reviewed)	`ea43dbaa`

The findings above reflect the assessed source and the remediation at `b50d0c3b`.

10 Limitations

- This is a source, bytecode, and offline-simulation review of the frozen revisions. It is not a live mainnet audit of the currently deployed packages.
- Deployment parity, whether the deployed packages match the reviewed revision, was not established from on-chain data, and no live value-at-risk quantification was performed.
- The `blast_sui` liquid-staking package does not compile at the frozen revision, its upgrade policy lives in modules deleted before the frozen head, and its current deployment and any live value are unknown. The absence of a deployment record and the compile break do not establish that no live `blast_sui` value exists.

- Comparison with public audits of comparable liquid-staking products is reference material only; similarity does not establish the absence of all risk in `blast_sui`.

The conclusions apply to the revisions and tests described in this report. They are not a certification of the currently deployed system.

11 Appendix: source references

Related security assessments:

- Asymptotic, Blast Launchpad security report (October 2026). https://raw.githubusercontent.com/interest-protocol/blast-v2-contracts/850d8227edce340a6d5d839d30efbd14b707dfc6/audits/blast-launchpad-asymptotic-oct-2026.pdf
- OtterSec, Cetus CLMM security assessment (June 6, 2025). https://raw.githubusercontent.com/CetusProtocol/Audit/e6cde26e7505281af6c7a3167fc4b18c54b85f6c/01-clmm/reports/Jun%202025-CLMM%20Audit%20by%20OtterSec.pdf
- Zellic, CetusProtocol smart contract security assessment (April 11, 2025). https://raw.githubusercontent.com/CetusProtocol/Audit/e6cde26e7505281af6c7a3167fc4b18c54b85f6c/01-clmm/reports/Apr%202025-CLMM%20Audit%20by%20Zellic.pdf

Liquid-staking reference corpus: ten public audit reports and 28 finding records covering SpringSui, Aftermath, Volo, Haedal, and Suilend. One entry is an adjacent lending-vault report, not a core liquid-staking report. These are reference and analogy material only.

Reviewed source: `interest-protocol/blast-v2-contracts` at the revisions in section 3.2.